Message house

Every Project Rampart message rests on one governing message and three pillars: reporting is already law, market access is the binding constraint, and compliance is an evidence system.

Governing message and pillars

Governing message (leaders and the board). The CRA turns product cybersecurity into a licence to sell in the EU. Example Group can be ready by 11 Dec 2027, but only if it secures third-party assessment capacity and builds shared compliance infrastructure in the next two quarters.

The answer (Project Rampart). A 14-month, three-wave programme: build shared capabilities once (PSIRT, SBOM, secure updates, evidence system), apply them product by product, and lock in notified-body capacity by Q1 2027. About EUR 9.3m to Dec 2027 and EUR 1.8m a year to run.

Staff version. Security is now part of what we sell: report a suspected vulnerability within the hour, and build the evidence as you build the product.

External version (customers, partners, public). Security is part of what we sell. We are registered to report actively exploited vulnerabilities and severe incidents to EU authorities within 24 hours, as the Cyber Resilience Act has required since 11 Sep 2026, and we are preparing every product family to meet the Act in full by 11 Dec 2027.

Exhibit 6: The three pillars and their proof points

Pillar	Message	Proof from the law (as at 30 Oct 2026)	Proof from Example Group (illustrative)
1. Reporting is already law	Every in-scope product, legacy included, is on a 24-hour reporting clock today.	Article 14 has applied since 11 Sep 2026 to every in-scope product, including those already on the market (Art 69(3)). Early warning in 24 hours, notification in 72 hours, final report 14 days after a fix (vulnerability) or one month after the notification (incident). Reports go through ENISA's Single Reporting Platform to Germany's coordinator CSIRT.	Platform registration and CSIRT decision done on 10 Sep 2026; 3 Assigned Representatives registered; first drill filed an early warning in 9h 40m (22 Oct 2026); 4 cases assessed, none reportable. Art 14 reporting is our strongest domain at 72% readiness. Legacy fleets stay reportable: T100 (1.1m units), HomeHub H2 (420k), V0 (260k).
2. Market access is the binding constraint	EUR 468m of annual EU revenue sits in Class I and II products that need a notified body, and none was verifiably designated at checks to 8 Sep 2026.	No harmonised standard is cited, so Class I products cannot self-assess under Module A. No CRA notified body was verifiably designated at checks to 8 Sep 2026; Member States must only 'strive' for enough bodies by 11 Dec 2026 (Art 35(2)). Commentary puts designation at 12 to 18 months (unverified).	Seven of 13 families; 39% of group revenue. Conformity and market access is our weakest domain at 16%. Three candidate bodies shortlisted, one proposal received. Pre-assessments due 29 Jan 2027 and formal contracts 31 Mar 2027, both At risk. Module H endorsed for five IC and S&S families (SD1).

Pillar	Message	Proof from the law (as at 30 Oct 2026)	Proof from Example Group (illustrative)
3. Compliance is an evidence system, not a project	Build once, apply per product version, sustain for ten years.	An Annex VII technical file per product version; documentation and declaration kept for 10 years or the support period, whichever is longer (Art 13(13)). The Product Liability Directive (EU) 2024/2853 applies to products placed on the market or put into service after 9 Dec 2026: software is a product and records can be disclosed in court.	Documentation readiness 24%. Signed SBOMs on 38% of releases (target 100% by 31 Mar 2027). System of record to be selected by 18 Dec 2026. Running cost EUR 1.8m a year from 2028.

Source: Project Rampart storyline and programme data, SteerCo #1 (30 Oct 2026); knowledge base, Reporting obligations, Conformity, Enforcement; RD12 is commentary; Illustrative

Foundation: how we speak. Accurate, calm and specific. We say what we do and by when. We never over-claim compliance, never disclose an unfixed vulnerability and never speculate during an incident.

Audience translations

Each audience hears the same message in its own terms, with one proof point and one ask.

Exhibit 7: The governing message, translated by audience

Audience	What it means for you	Proof point to use	Our ask	Avoid
Board	A funded 14-month programme protects EUR 468m of EU revenue; five decisions on 19 Nov 2026.	387 days from the board to 11 Dec 2027; EUR 9.3m one-off is 0.77% of one year's revenue; readiness 44% today.	Take decisions BD1 to BD5; hold management to the notified-body milestones (29 Jan and 31 Mar 2027).	Legal detail; certainty about when notified bodies will exist.
Engineers and product teams	Evidence comes from the pipeline, not from paperwork; the release gate checks what you already test.	Signed SBOMs on 38% of releases today, 100% by 31 Mar 2027; release gate enforced on the T200 and IR-500 trains by 22 Jan 2027.	Report suspected exploitation to PSIRT within the hour; complete your training; generate the SBOM from the build.	'Compliance paperwork'; security as the reason for delay.
Sales and support	Say what we do and when; never 'CRA certified'; route vulnerability reports to PSIRT within the hour.	CVD policy and security.txt live for HBS and S&S by 4 Dec 2026; customer FAQ live 8 Dec 2026; declarations per product before 11 Dec 2027.	Answer from the FAQ; send anything it does not cover to [CRA questions mailbox].	Improvised legal answers; product-specific dates not yet published.

Audience	What it means for you	Proof point to use	Our ask	Avoid
B2B customers and integrators	You will have the evidence your own NIS2 and CRA duties need: support periods, a vulnerability contact, SBOM on request and declarations on a published timetable.	We registered for Art 14 reporting on 10 Sep 2026 and tested it in a drill on 22 Oct 2026; advisories in human-readable and machine-readable (CSAF) form.	Use the FAQ and trust page; send questionnaires to [address].	‘Compliant today’; ‘certified’.
Consumers	Automatic security updates by default and a clear support end date at purchase.	From 11 Dec 2027 the end of support is shown as month and year at purchase; security updates are free of charge.	Keep automatic updates switched on.	Regulatory jargon; fear.
Suppliers	We need vulnerability notification, SBOMs and support commitments; here is the clause pack.	The CRA makes us answerable for every component we ship (Art 13(5)); 6 of 41 in-scope suppliers are on CRA clauses today.	Sign the clause pack (top 15 by Jan 2027, all by Jun 2027); answer the questionnaire.	Threats; implying a supplier becomes ‘CRA certified’ by signing.

Audience	What it means for you	Proof point to use	Our ask	Avoid
Channel partners (distributors, importers, retail)	We will supply DoCs, Annex II information and CE marking per product before 11 Dec 2027; your own checks are short and defined.	Declarations, CE marking and Annex II information due by 3 Dec 2027 (M13); partner portal page per product.	Forward vulnerability reports to PSIRT without undue delay; do not modify or rebrand products without talking to us.	Legal advice on their obligations beyond the text of Arts 19 and 20.
Regulators (Germany's coordinator CSIRT and market surveillance authority)	We report on time with complete data and answer reasoned requests within 10 working days.	Three registered Assigned Representatives; UTC case records; drill results.	None: answer what is asked, completely.	Argument, speculation, opinion beyond the facts.
Notified bodies (candidates)	We are assessment-ready early and want a slot with conversion options.	IEC 62443-4-1 certified development process (IC, 2024) as the Module H base; EN 18031-1 assessments (HBS, 2025); complete Module A records.	A pre-assessment proposal by [date].	Pressure on designation timing; requests for commitments a body cannot yet give.

Source: Project Rampart stakeholder register and programme data; knowledge base, Annex I Part II and Economic operators and roles; Illustrative

Say / don't say

Say what we do and by when; never claim a status we have not yet earned.

Exhibit 8: Approved and prohibited phrasing

Topic	Say	Don't say	Why
Our status	'We are preparing every product family to meet the CRA by 11 Dec 2027.'	'Our products are CRA compliant' or 'fully compliant'.	Product requirements apply from 11 Dec 2027, and compliance is declared per product in a signed declaration of conformity; none is signed yet.
Certification	'From 11 Dec 2027 our products will carry CE marking under the CRA, backed by an EU declaration of conformity; for some categories an independent notified body assesses them first.'	'CRA certified', 'CRA approved', 'CRA-ready'.	There is no general CRA certificate. The manufacturer declares conformity; a notified body is involved only for certain categories.
Existing certificates	'Our IEC 62443-4-1 certified process and EN 18031 assessments give us a head start.'	'Our certificates mean we already meet the CRA.'	No harmonised standard is cited for the CRA; RED evidence shows RED conformity, not CRA conformity.
Reporting	'We report actively exploited vulnerabilities and severe incidents to the authorities within 24 hours, as the law has required since 11 Sep 2026.'	'We have never had a reportable incident'; 'we report every vulnerability'.	The first is a point-in-time fact that invites challenge; the second is wrong, because only actively exploited vulnerabilities and severe incidents are mandatory.

Topic	Say	Don’t say	Why
Incidents and vulnerabilities	‘We are investigating and will update you by [time].’ ‘Version [x] fixes the issue; please install it.’	Causes, attackers, impact or affected components before they are confirmed; any exploit detail before a fix; any blame on a supplier, researcher or customer.	No speculation, no blame and no disclosure that helps attackers (tab 7).
Notified bodies	‘We have engaged candidate notified bodies early to secure assessment capacity.’	‘[Body] is certifying our products’; ‘[Body] has approved us’.	No CRA notified body was verifiably designated at checks to 8 Sep 2026; a pre-assessment is not a conformity assessment.
SBOM	‘We keep an SBOM for every release; B2B customers can request it under [terms].’	‘Our SBOMs are public’; ‘the law requires us to give you our SBOM’.	The SBOM is part of the technical documentation and need not be made public (Recital 77).
Support period	‘Security updates for [product] until [month year].’	‘Lifetime support’; any support period not yet confirmed by product management.	The support period is a declared commitment with legal weight (Art 13(8), (19)).
Timeline	‘Reporting has applied since 11 Sep 2026; everything else applies from 11 Dec 2027.’	‘The CRA starts in 2027’; ‘the Digital Omnibus will delay it’.	Reporting is already live; the Digital Omnibus proposal does not amend the CRA and is not adopted.

Topic	Say	Don’t say	Why
Penalties	Internal only: ‘Fines can reach EUR 15m or 2.5% of worldwide turnover, whichever is higher.’	‘We face a EUR 30m fine’ in any external or all-staff message.	Fear does not change behaviour. Fines and most market-surveillance enforcement apply from 11 Dec 2027; Finland can already enforce Article 14 breaches (since 11 Sep 2026).
Open source	‘We take responsibility for the open-source components in our products and report vulnerabilities upstream.’	‘Open-source projects must now comply with the CRA’; ‘maintainers must give us SBOMs’.	Integrating open source leaves the manufacturer’s due-diligence duty in place (Art 13(5)); stewards have a light-touch regime (Art 24).
Products already sold	‘Products already in the field are covered by our reporting duty and supported on their stated terms.’	‘Old products are out of scope.’	Art 14 reporting applies to products placed on the market before 11 Dec 2027 (Art 69(3)).

Source: knowledge base (Executive summary, Reporting obligations, Conformity, Standards, Open-source software), facts as at 30 Oct 2026; Illustrative

Approved glossary

Use these 15 terms, in these words, in every message; define any other term on first use or leave it out.

Exhibit 9: Fifteen CRA terms in plain English

Term	Plain-English meaning	Basis
Product with digital elements	Any hardware or software product that connects to a device or network, together with the cloud services we build that it needs to work (‘remote data processing’). For us: 13 families, their apps and backends.	Art 3(1)-(2)
Important product (Class I, Class II)	A product in a category the CRA lists as higher risk: 19 Class I and 4 Class II categories. Seven of our families are important: six Class I and one Class II (SG-900).	Art 7; Annex III
Actively exploited vulnerability	A weakness for which there is reliable evidence that an attacker has used it against a system without permission. A proof of concept or a scanner finding alone is not enough.	Art 3(42)
Severe incident	An incident that harms, or could harm, a product’s ability to protect sensitive data or functions, or that leads to malicious code running in the product or in users’ systems.	Art 14(5)
Early warning	The first report to the authorities, due within 24 hours of becoming aware; a fuller notification follows at 72 hours, then a final report. We file on ENISA’s Single Reporting Platform to Germany’s coordinator CSIRT.	Art 14(2), (4), (7)

Term	Plain-English meaning	Basis
PSIRT	Our product security incident response team. It receives vulnerability reports, decides when we are ‘aware’ and files Article 14 reports. It is separate from the team that protects our own IT.	Corporate guide 07
Coordinated vulnerability disclosure (CVD)	Our published rules for how anyone can report a vulnerability to us, how we respond, and when we publish fixes and advisories.	Annex I Part II(5)-(6)
Software bill of materials (SBOM)	A machine-readable list of the software components in a product release. It is part of our technical documentation and is not public by law.	Annex I Part II(1); Recital 77
Support period	The time during which we handle vulnerabilities and provide security updates: at least five years unless the product is expected to be used for less. From 11 Dec 2027 its end date is shown at purchase.	Art 13(8), (19)
Annex II user information	The security information that travels with each product: our contact details, the vulnerability contact, how to install updates, the support end date and where to find the declaration.	Art 13(18); Annex II
Conformity assessment	The procedure that shows a product meets the CRA: self-assessment (Module A), type examination plus production control (Module B+C), or approval of the whole quality system (Module H).	Art 32; Annex VIII

Term	Plain-English meaning	Basis
Notified body	An independent assessment organisation designated by a Member State to run Module B+C or Module H. None was verifiably designated for the CRA at checks to 8 Sep 2026.	Arts 35-51
Harmonised standard	A European standard cited in the Official Journal that gives a presumption of conformity. None is cited for the CRA as at 30 Oct 2026.	Art 27(1)
Technical documentation	The evidence file kept for each product version: description, risk assessment, support-period information, standards applied, test reports and SBOM. Kept for at least 10 years.	Art 13(13); Annex VII
EU declaration of conformity and CE marking	Our signed statement that a product meets the CRA, and the mark that shows it. Both come only after a positive conformity assessment.	Arts 28, 30

Source: knowledge base (Scope, Classification, Reporting obligations, Annex I Part II, Conformity, Standards); Illustrative

Project Rampart · Communication Pack (D05) · Illustrative · v1.0 · 31 Oct 2026